COMPTE RENDU DU TP 4.1 SUR LA MISE EN PLACE D'UN PARE-FEU PFSENSE ET SEGMENTATATION DU LABORATOIRE

1. Introduction et objectifs techniques

Ce travail pratique vise à mettre en place une architecture réseau sécurisée basée sur un pare-feu pfSense afin de segmenter un environnement de laboratoire initialement plat et non sécurisé.

Dans les TPs précédents, toutes les machines (Kali, Ubuntu, Windows) étaient connectées sur un même réseau Host-Only sans contrôle des flux. Cette architecture est non réaliste et dangereuse car elle permet une communication libre entre attaquant et machines cibles.

L'objectif de ce TP est donc de :

- introduire une séparation réseau (LAN / WAN),
- centraliser le contrôle des flux via pfSense,
- appliquer des règles de filtrage,
- simuler une architecture d'entreprise réelle.

2. Architecture cible et principes de segmentation

L'architecture à construire repose sur un principe fondamental de la sécurité réseau : la segmentation.

- Le réseau interne (LAN) est la zone dite « fiable ». Elle contient les actifs critiques de l'entreprise : le **serveur Ubuntu** et le **poste Windows**. Ces machines n'ont normalement pas besoin d'être directement accessibles depuis l'extérieur. Leurs communications sortantes doivent être contrôlées, et leurs communications entrantes doivent être strictement limitées.

- Le réseau externe (WAN) représente l'extérieur, c'est-à-dire Internet ou tout autre réseau non maîtrisé. Dans ce laboratoire, la machine Kali (attaquant) est placée dans cette zone. Elle ne doit pas pouvoir accéder directement aux machines internes sans autorisation explicite du pare-feu.

- **Le pare-feu pfSense** est placé à la frontière entre ces deux zones. Toute communication d'une zone vers l'autre doit passer par lui. Il applique des règles de filtrage qui déterminent quel trafic est autorisé et quel trafic est bloqué. Cette architecture est extrêmement proche de ce que l'on trouve dans les entreprises réelles, où des pare-feu d'entreprise (comme Fortinet, Palo Alto, Check Point ou pfSense) assurent la séparation entre les différents segments réseau.

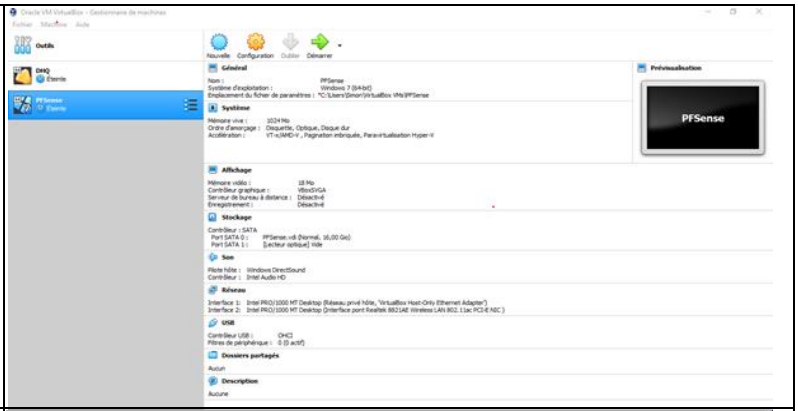
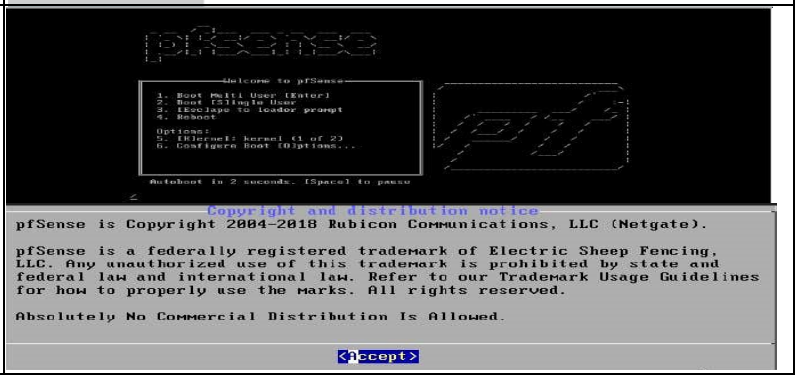
3. installation de pfsense

Pfsense est installé sur une distribution FreeBSD, existante sous format ISO téléchargeable. La configuration matérielle minimale requise pour Pfsense est la suivante :

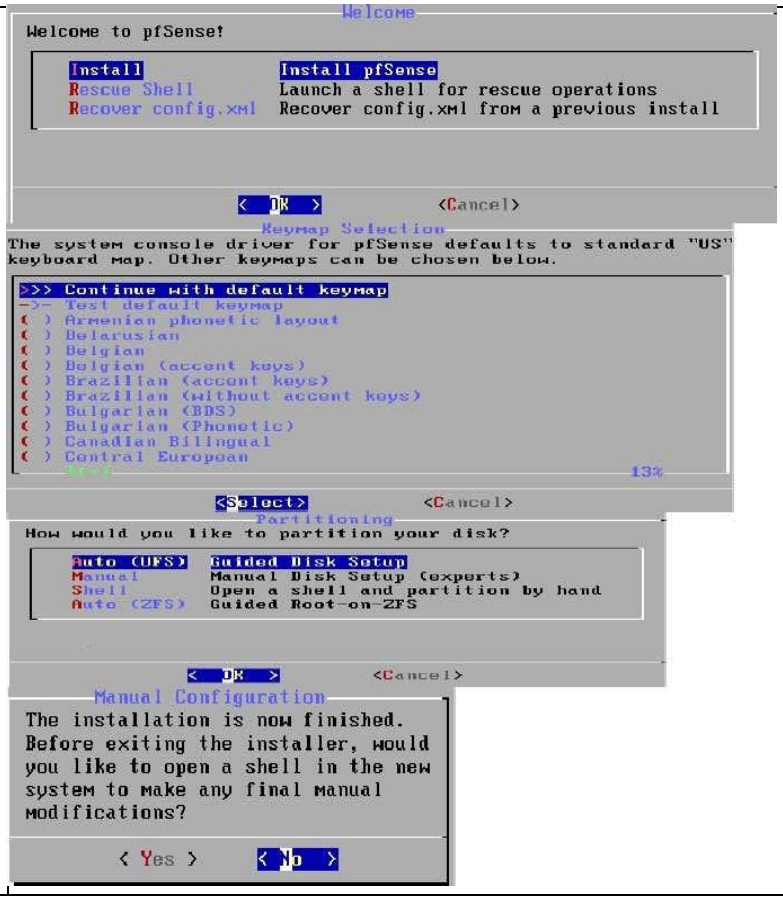
- CPU 600 Mhz ou plus rapide ;
- RAM 512 Mo ou plus ;
- 4GoHDD ;
- Deux ou plusieurs cartes d'interfaces réseau compatibles.

Pour une meilleure gestion et organisation du travail nous utilisons une machine virtuelle (Virtual box). Les différentes étapes d'installation de Pfsense sont résumées dans le tableau ci-dessous :

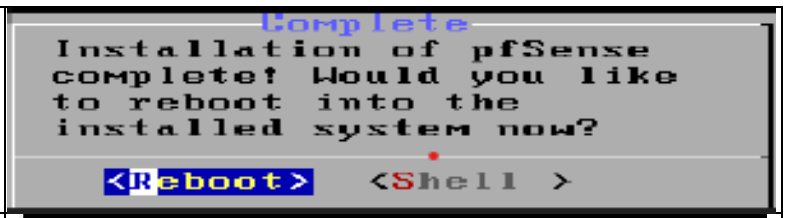
Tableau : Etapes d'installation de Pfsense

Etape 1 : installation et configuration de la VM.	
Etape 2 : accès au menu de démarrage de Pfsense après le chargement de l'ISO dans la machine virtuelle.	

Etape 3 : choix des options d'installation par défaut.



Etape 4 : Redémarrage de la machine pour que les changements soient effectifs.



Etape 5 : assignation des interfaces LAN et WAN exemple :

LAN :192.168.2.1

WAN :192.168.0.254

4. Modification du réseau des machines existantes (Ubuntu et Windows)

Les machines Ubuntu et Windows, qui étaient auparavant connectées à un réseau Host-Only sans passerelle contrôlée, ont dû être reconfigurées pour utiliser pfSense comme passerelle.

Dans VirtualBox, les paramètres réseau de la machine Ubuntu ont été modifiés pour que son adaptateur soit en mode Host-Only, sur le même réseau Host-Only que l'interface LAN de pfSense. Une fois cette modification effectuée, les adresses IP des machines ont été configurées manuellement pour éviter toute erreur d'attribution DHCP

- Sur Ubuntu, l'adresse a été configuree en executant la commande: **sudo ip addr add 192.168.1.10/24 dev eth0** et verifiee grace a la commande **ip a**

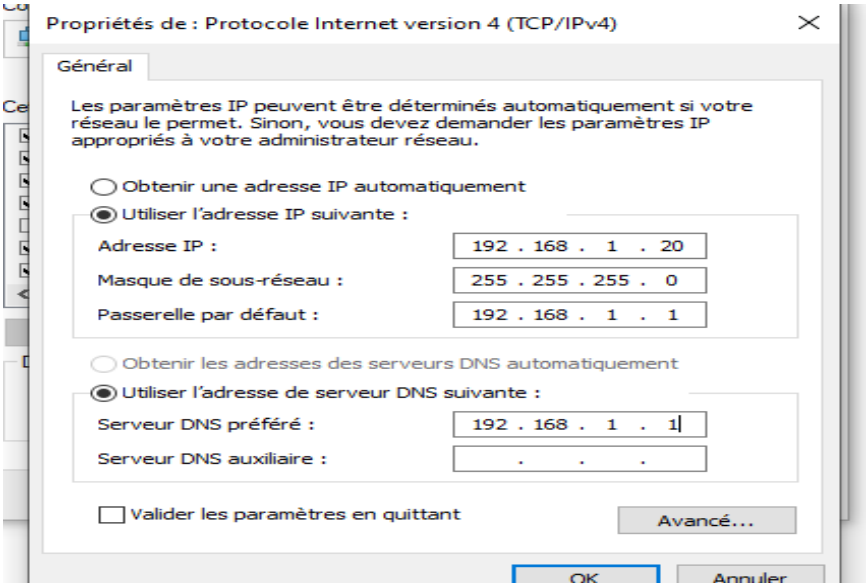
```
tagne@tagne-VirtualBox:~$ sudo ip addr add 192.168.1.10/24 dev enp0s8
tagne@tagne-VirtualBox:~$ ip a
```

```
3: enp0s8: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether 08:00:27:fa:b1:c1 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.10/24 brd 192.168.56.255 scope global noprefixroute enp0s8
       valid_lft forever preferred_lft forever
    inet 192.168.1.10/24 scope global enp0s8
       valid_lft forever preferred_lft forever
    inet6 fe80::5117:f55:c6c8:b549/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

La route a été crée grace a la commande : **sudo ip route add default via 192.168.1.1** et vérifiée avec **ip route**

```
tagne@tagne-VirtualBox:~$ sudo ip route add default via 192.168.1.10
tagne@tagne-VirtualBox:~$ ip route
default via 192.168.1.10 dev enp0s8
default via 10.0.2.2 dev enp0s3 proto dhcp metric 20100
default via 192.168.56.1 dev enp0s8 proto static metric 20101
10.0.2.0/24 dev enp0s3 proto kernel scope link src 10.0.2.15 metric 100
169.254.0.0/16 dev enp0s8 scope link metric 1000
192.168.1.0/24 dev enp0s8 proto kernel scope link src 192.168.1.10
192.168.56.0/24 dev enp0s8 proto kernel scope link src 192.168.56.10 metric 101
```

- Sur Windows, la configuration a été réalisée via l'interface graphique des paramètres réseau. L'adresse IP a été définie à 192.168.1.20, le masque de sous-réseau à 255.255.255.0 et la passerelle par défaut à 192.168.1.1. Le serveur DNS a été provisoirement configuré à 192.168.1.1



Cette configuration manuelle garantit que chaque machine a une adresse IP fixe et connue, ce qui facilite les tests et la configuration des règles de pare-feu.

5. Vérification de la connectivité avec pfSense

Avant de procéder plus loin, la connectivité entre les machines internes et pfSense a été testée. Depuis Ubuntu, la commande suivante a été exécutée : **ping 192.168.1.1**

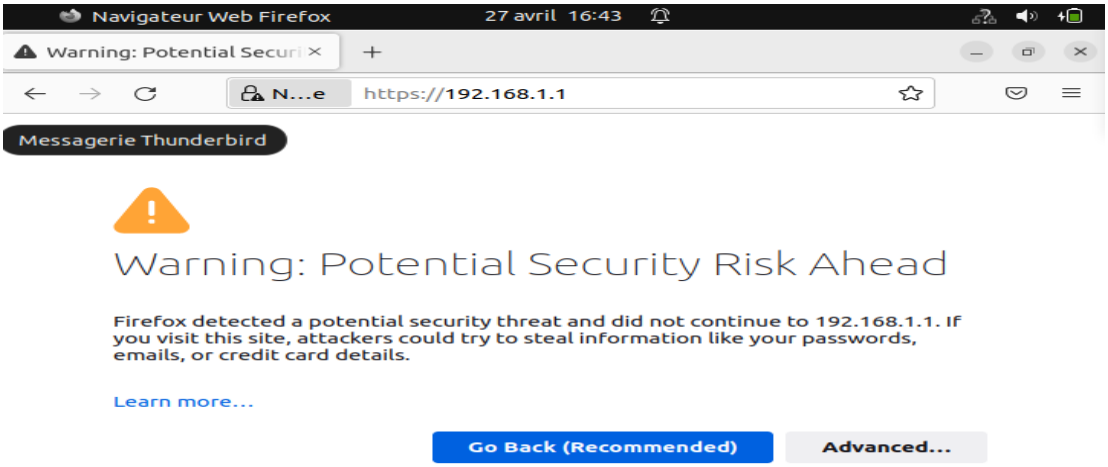
```
tagne@tagne-VirtualBox:~$ ping 192.168.1.1
PING 192.168.1.1 (192.168.1.1) 56(84) bytes of data.
64 bytes from 192.168.1.1: icmp_seq=1 ttl=64 time=0.830 ms
64 bytes from 192.168.1.1: icmp_seq=2 ttl=64 time=0.718 ms
64 bytes from 192.168.1.1: icmp_seq=3 ttl=64 time=0.596 ms
64 bytes from 192.168.1.1: icmp_seq=4 ttl=64 time=0.695 ms
64 bytes from 192.168.1.1: icmp_seq=5 ttl=64 time=0.594 ms
64 bytes from 192.168.1.1: icmp_seq=6 ttl=64 time=0.613 ms
64 bytes from 192.168.1.1: icmp_seq=7 ttl=64 time=0.537 ms
64 bytes from 192.168.1.1: icmp_seq=8 ttl=64 time=0.550 ms
64 bytes from 192.168.1.1: icmp_seq=9 ttl=64 time=0.441 ms
```

Des réponses ICMP (Internet Control Message Protocol) ont été reçues, confirmant que pfSense était joignable. Le temps de réponse, typiquement inférieur à une milliseconde, indique une latence très faible caractéristique d'un réseau virtuel.

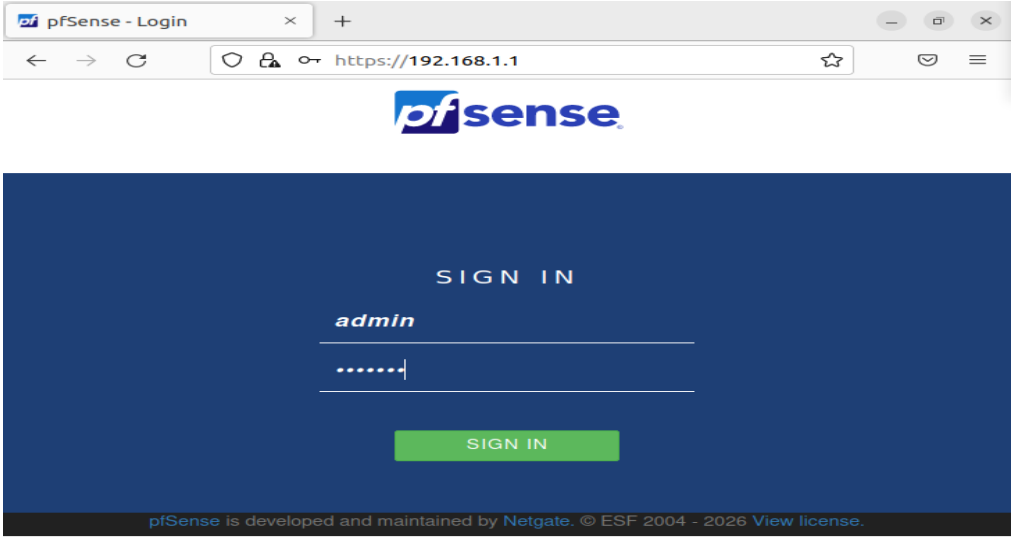
6. Accès à l'interface web de pfSense

pfSense se configure principalement via une interface web, ce qui est beaucoup plus pratique que la console textuelle. Depuis Ubuntu , le navigateur web mozilla firefox a été ouvert à l'adresse suivante : **https://192.168.1.1**

Le navigateur a affiché un avertissement de sécurité concernant le certificat TLS auto-signé de pfSense. Une exception a été ajoutée pour autoriser l'accès.



L'interface de connexion est apparue. Les identifiants par défaut de pfSense sont admin pour le nom d'utilisateur et pfsense pour le mot de passe :



Cette interface web est le cœur de l'administration du pare-feu. Toutes les règles de filtrage, les configurations réseau, les services DHCP, DNS, et les outils de surveillance y sont accessibles.

7. Vérification de l'accès à Internet depuis Ubuntu

Avant de configurer des règles de filtrage, l'accès à Internet depuis le réseau interne a été testé. Depuis Ubuntu, la commande suivante a été exécutée : **ping 8.8.8.8**

```
tagne@tagne-VirtualBox:~$ ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=112 time=58.9 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=112 time=44.4 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=112 time=95.8 ms
64 bytes from 8.8.8.8: icmp_seq=5 ttl=112 time=136 ms
64 bytes from 8.8.8.8: icmp_seq=6 ttl=112 time=55.5 ms
64 bytes from 8.8.8.8: icmp_seq=7 ttl=112 time=55.2 ms
64 bytes from 8.8.8.8: icmp_seq=8 ttl=112 time=53.4 ms
64 bytes from 8.8.8.8: icmp_seq=9 ttl=112 time=609 ms
64 bytes from 8.8.8.8: icmp_seq=10 ttl=112 time=215 ms
```

L'adresse 8.8.8.8 est un serveur DNS public de Google, souvent utilisé comme cible de test car elle est presque toujours accessible. La commande a réussi, avec des réponses ICMP provenant de 8.8.8.8. Cela signifie que pfSense route correctement le trafic.

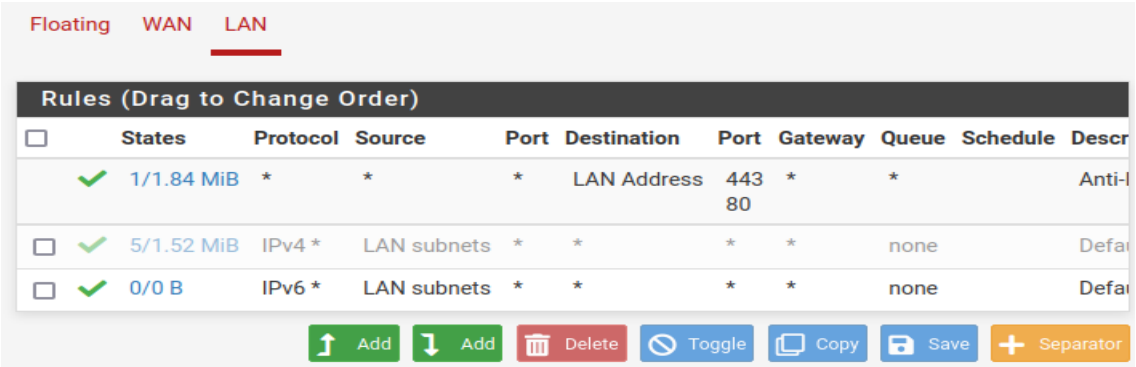
Ce test valide que l'architecture est fonctionnelle. pfSense assure déjà deux fonctions essentielles :

- ✓ le routage entre les deux réseaux (LAN et WAN)
- ✓ la traduction d'adresses (NAT) qui masque les adresses internes (192.168.1.x) derrière l'adresse IP de l'interface WAN de pfSense.

8. Mise en place d'une règle de filtrage

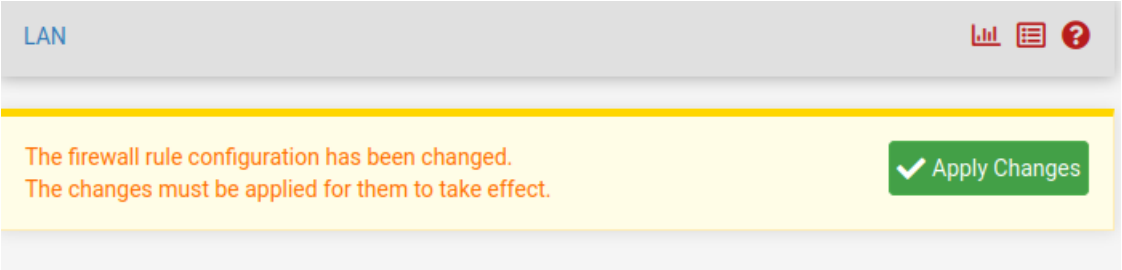
Jusqu'à présent, pfSense autorise tout le trafic par défaut. Cela est utile pour valider l'architecture, mais cela ne constitue pas une protection. L'objectif est maintenant de restreindre le trafic pour ne permettre que ce qui est strictement nécessaire.

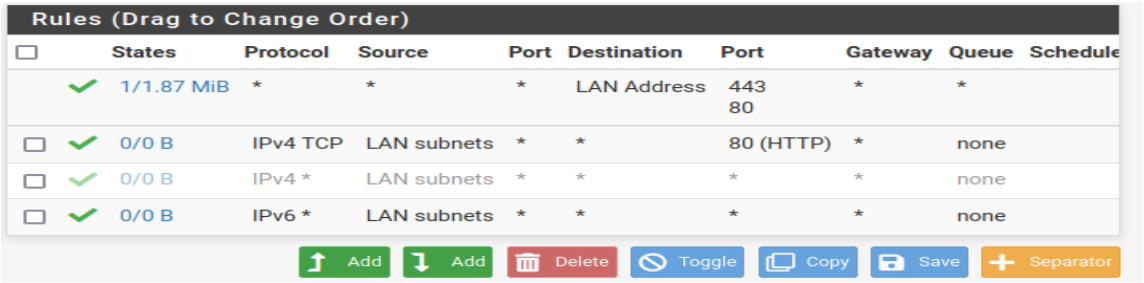
- ❖ Dans l'interface web de pfSense, le menu **Firewall → Rules → LAN** a été sélectionné. Une règle par défaut était présente, autorisant tout le trafic Cette règle a été désactivée en cliquant sur l'icône en forme de fiche à droite de la ligne, puis en validant la désactivation.



❖ Ensuite, une nouvelle règle a été créée en cliquant sur le bouton Add en haut de la liste. Les differents paramètres ont été configurés

La règle a été sauvegardée, puis les modifications ont été appliquées en cliquant sur Apply Changes.





À ce stade, le pare-feu autorise uniquement le trafic TCP sortant vers le port 80 (HTTP) depuis le réseau interne. Tout autre trafic (ICMP, TCP vers d'autres ports, UDP, etc.) est implicitement bloqué par la règle de fin de liste qui refuse tout ce qui n'est pas explicitement autorisé.

9. Tests de fonctionnement et validation des règles

Des tests ont été réalisés depuis Ubuntu pour valider le comportement attendu.

✓ Le premier test a consisté à vérifier que le trafic HTTP (port 80) fonctionne toujours. La commande suivante a été exécutée : **curl** **http://example.com**

```
tagne@tagne-virtualbox: ~
tagne@tagne-virtualbox:~$ curl http://example.com
<!doctype html>
<html>
<head>
    <title>Example Domain</title>

    <meta charset="utf-8" />
    <meta http-equiv="Content-type" content="text/html; charset=utf-8" />
    <meta name="viewport" content="width=device-width, initial-scale=1" />
</head>

<body>
<div>
      <h1>Example Domain</h1>
      <p>This domain is for use in illustrative examples in documents.</p>
      <p><a href="https://www.iana.org/domains/example">More information...</a></p>
</div>
</body>
</html>
```

La commande a réussi. Le serveur web de example.com a renvoyé une page HTML, et curl l'a affichée dans le terminal. Cela confirme que la règle TCP port 80 autorise bien le trafic.

- ✓ Le second test a consisté à vérifier que le trafic ICMP (ping) est maintenant bloqué. La commande suivante a été exécutée : **ping 8.8.8.8**

```
tagne@tagne-VirtualBox:~$ ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
```

La commande n'a reçu aucune réponse. Après quelques secondes, le message Destination Port Unreachable ou simplement l'absence de réponse est apparu. Le pare-feu a bloqué les paquets ICMP car aucune règle ne les autorise.

- ✓ Le troisième test a consisté à vérifier qu'un scan Nmap depuis Ubuntu vers l'extérieur est entravé. La commande suivante a été exécutée : **nmap -sS 8.8.8.8**

```
tagne@tagne-VirtualBox:~$ sudo nmap -sS 8.8.8.8
Starting Nmap 7.80 ( https://nmap.org ) at 2026-04-27 18:42 CEST
Note: Host seems down. If it is really up, but blocking our ping probes, try -P
n
Nmap done: 1 IP address (0 hosts up) scanned in 3.11 seconds
```

Le scan a échoué. Nmap a envoyé des paquets SYN vers différents ports de 8.8.8.8, mais pfSense a bloqué ces paquets car ils ne correspondent pas à la règle (port 80 uniquement). Le résultat a montré que tous les ports sont filtrés ou fermés.

Ces tests démontrent que le pare-feu exerce désormais un contrôle précis sur le trafic. Seul le trafic HTTP sortant est autorisé. Tout le reste, y compris les pings, les scans, et les connexions vers d'autres ports, est bloqué.

10. Analyse technique des règles et interprétation

La règle mise en place illustre le principe du **filtrage par liste blanche** : tout est bloqué par défaut, seules les communications explicitement autorisées peuvent passer. C'est l'approche la plus sécurisée.

❖ La règle autorise le trafic TCP vers le port 80. Le protocole TCP est orienté connexion, fiable, et garantit la livraison dans l'ordre des paquets. Le port 80 est le port standard du protocole HTTP (Hypertext Transfer Protocol), utilisé pour le trafic web non chiffré. Dans un environnement réel, on autoriserait également le port 443 (HTTPS, chiffré), mais ce TP se limite au port 80 pour simplifier.

❖ Le blocage du ping (protocole ICMP) démontre que le pare-feu ne se limite pas à filtrer les ports TCP et UDP. ICMP est un protocole différent, utilisé pour les messages de contrôle et d'erreur (comme le ping). Bloquer ICMP est une pratique courante pour réduire la visibilité du réseau et empêcher certaines techniques de découverte.

❖ Le blocage du scan Nmap montre qu'un attaquant qui compromettrait une machine interne ne pourrait pas l'utiliser pour scanner librement d'autres cibles. Le scan est bloqué car il envoie des paquets vers des ports non autorisés. Cela limite considérablement la capacité de pivotement et d'exploration latérale.

11. Simulation d'un comportement d'attaquant et interprétation

La figure cicontre illustre une tentative scan depuis Kali bloquée

```
┌──(tagne㉿laura)-[~]
└─$ sudo nmap -sS 192.168.1.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-28 04:50 +0200
Nmap scan report for 192.168.1.10
Host is up (0.061s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT     STATE SERVICE
8010/tcp open  xmpp

Nmap done: 1 IP address (1 host up) scanned in 29.54 seconds
```

Analyse : Le pare-feu empêche la reconnaissance réseau.

Les conséquences pour un attaquant sont graves :

- ✓ les communications vers un serveur de commande et de contrôle (C2) sont entravées. Un attaquant qui utilise un reverse shell classique (connexion sortante vers un port comme 4444, 1337, etc.) se verra bloqué car seul le port 80 est autorisé.
- ✓ l'exfiltration de données est limitée. Exporter des fichiers volumineux vers un serveur externe via des ports non standards est impossible.
- ✓ les scans de découverte sont bloqués, empêchant l'attaquant de cartographier le réseau environnant.

12. Recommandations de sécurité pour l'entreprise NetSecure

À l'issue de ce TP, plusieurs recommandations peuvent être formulées pour l'entreprise NetSecure.

- **La première recommandation concerne la segmentation réseau**. L'entreprise doit segmenter son système d'information en plusieurs zones de sécurité. Par exemple, une zone pour les serveurs (DMZ), une zone pour les postes utilisateurs, une zone pour l'administration, et une zone pour les systèmes sensibles (bases de données). Chaque zone doit avoir ses propres règles de pare-feu, et les flux entre zones doivent être strictement contrôlés et justifiés.

- **La deuxième recommandation concerne la politique de filtrage par défaut.** La règle implicite de fin de liste doit être « tout bloquer ». Seuls les flux nécessaires au fonctionnement

de l'entreprise doivent être explicitement autorisés. Cette approche, dite « whitelist », est beaucoup plus sécurisée que l'approche « blacklist » (autoriser tout sauf ce qui est connu comme malveillant).

- **La troisième recommandation concerne la limitation des ports autorisés.** L'entreprise doit autoriser uniquement les ports strictement nécessaires. Par exemple, pour l'accès à Internet depuis les postes utilisateurs, seuls les ports 80 (HTTP) et 443 (HTTPS) sont sont généralement nécessaires. Les ports de services administratifs (SSH, RDP) ne doivent pas être accessibles depuis le réseau externe, et depuis le réseau interne uniquement depuis des postes d'administration dédiés.

- **La quatrième recommandation concerne la mise en place d'une zone démilitarisée (DMZ)**. Les serveurs accessibles depuis l'extérieur (serveur web, serveur mail, etc.) doivent être placés dans une DMZ, une zone séparée entre le réseau externe et le réseau interne. Les règles de pare-feu doivent autoriser uniquement les flux strictement nécessaires vers ces serveurs, et les serveurs de la DMZ ne doivent pas pouvoir initier de connexions vers le réseau interne.
- **La cinquième recommandation concerne la journalisation et la supervision**. pfSense peut journaliser tous les flux bloqués et autorisés. Ces logs doivent être centralisés pour permettre une analyse en temps réel et une détection d'anomalies.

13. Conclusion

Ce travail pratique a permis de transformer un réseau totalement ouvert en une architecture segmentée et contrôlée par un pare-feu professionnel pfsense. La segmentation LAN/WAN associée à un filtrage strict permet : la réduction de surface d'attaque, le contrôle total des flux réseau, la limitation des actions d'un attaquant interne.

Ainsi, pfSense joue ici un rôle central dans la défense du système d'information, en appliquant une politique de sécurité par défaut restrictive.